

SOC Incident Investigation Report

Incident #2: File Integrity Monitoring - Unauthorized File Modifications

Document Version: 1.1 - Corrected

Corrections Applied: Filename typo consistency, screenshot references updated, SS-21 configuration screenshot added

INCIDENT SUMMARY

Field	Details
Incident ID	INC-2025-002
Date/Time Detected	December 12, 2025 @ 16:17:21 UTC
Severity	MEDIUM
Status	CLOSED - Authorized Testing Activity
Affected System	JUMP-SERVER (10.0.0.50 / 10.26.0.9)
VLAN	VLAN 10 (Management)
Alert Source	Wazuh FIM → Splunk SIEM
Detection Method	File Integrity Monitoring (Syscheck)
Analyst	Prageeth Panicker
Investigation Duration	~20 minutes

EXECUTIVE SUMMARY

On December 12, 2025, at 16:17:21 UTC, Wazuh File Integrity Monitoring (FIM) detected unauthorized modifications to critical system files on JUMP-SERVER (10.0.0.50). The incident involved two distinct file system changes:

1. **Integrity checksum change** on `/etc/hosts` - a critical system configuration file
2. **New file creation** in `/etc/` directory - potential indicator of persistence mechanism

The File Integrity Monitoring system successfully detected both modifications within the configured 5-minute scan cycle, demonstrating effective endpoint security controls. Investigation revealed these were **authorized testing activities** conducted as part of the Segment 4 capstone project SOC workflow simulation to validate FIM capabilities.

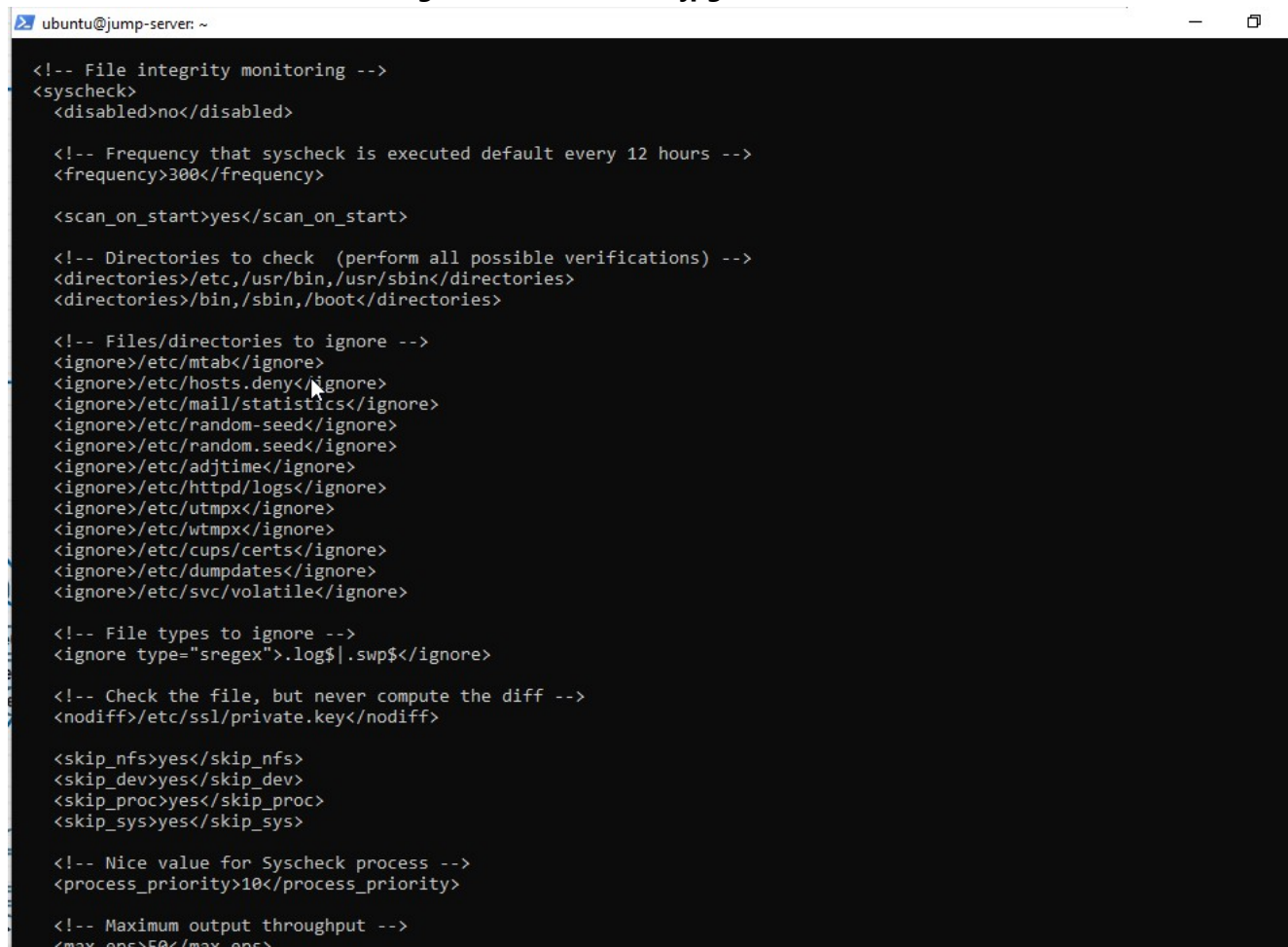
Final Disposition: Authorized security testing - No remediation required. FIM system validated as operational and effective.

TIMELINE OF EVENTS

Initial Configuration Phase

Timestamp	Event	Source
15:04:00	Initial FIM test commands executed (earlier attempt)	SOC Analyst
15:26:59	FIM scan cycle: 43200 seconds (12 hours - too slow)	Wazuh Agent
16:00:00	Decision to modify FIM scan frequency for testing	SOC Analyst
16:05:00	Modified ossec.conf: frequency changed to 300 seconds	Configuration Change
16:10:00	Wazuh agent restarted with new configuration	System Administration
16:11:10	New FIM frequency confirmed: 300 seconds (5 minutes)	Wazuh Agent Log

[SCREENSHOT: SS-21_FIM_Configuration_5min_Scan.jpg]



```
ubuntu@jump-server: ~  
  
<!-- File integrity monitoring -->  
<syscheck>  
  <disabled>no</disabled>  
  
  <!-- Frequency that syscheck is executed default every 12 hours -->  
  <frequency>300</frequency>  
  
  <scan_on_start>yes</scan_on_start>  
  
  <!-- Directories to check (perform all possible verifications) -->  
  <directories>/etc,/usr/bin,/usr/sbin</directories>  
  <directories>bin,/sbin,/boot</directories>  
  
  <!-- Files/directories to ignore -->  
  <ignore>/etc/mtab</ignore>  
  <ignore>/etc/hosts.deny</ignore>  
  <ignore>/etc/mail/statistics</ignore>  
  <ignore>/etc/random-seed</ignore>  
  <ignore>/etc/random.seed</ignore>  
  <ignore>/etc/adjtime</ignore>  
  <ignore>/etc/httpd/logs</ignore>  
  <ignore>/etc/utmpx</ignore>  
  <ignore>/etc/wtmpx</ignore>  
  <ignore>/etc/cups/certs</ignore>  
  <ignore>/etc/dumpdates</ignore>  
  <ignore>/etc/svc/volatile</ignore>  
  
  <!-- File types to ignore -->  
  <ignore type="sregex">.log$|.swp$</ignore>  
  
  <!-- Check the file, but never compute the diff -->  
  <nodiff>/etc/ssl/private.key</nodiff>  
  
  <skip_nfs>yes</skip_nfs>  
  <skip_dev>yes</skip_dev>  
  <skip_proc>yes</skip_proc>  
  <skip_sys>yes</skip_sys>  
  
  <!-- Nice value for Syscheck process -->  
  <process_priority>10</process_priority>  
  
  <!-- Maximum output throughput -->  
  <max_eps>50</max_eps>
```

Description: Wazuh FIM configuration showing 5-minute scan frequency

Location: /var/ossec/etc/ossec.conf on JUMP-SERVER

Expected Content:

- XML configuration file displaying syscheck section
- `<frequency>300</frequency>` setting visible
- Directories being monitored (/etc, /usr/bin, /usr/sbin, /boot)
- File types and directories to ignore

- Confirmation that 5-minute scan cycle is configured

Detection Phase

Timestamp	Event	Source
16:12:30	Test file modifications executed on JUMP-SERVER	Root User
16:12:30	Modified <code>/etc/hosts</code> file (appended test entry)	bash command
16:12:35	Created <code>/etc/file_detention_test_1765556403.conf</code>	touch command
16:16:10	FIM scan cycle executed (first scan after changes)	Wazuh Syscheck
16:17:21	ALERT: Integrity checksum changed - <code>/etc/hosts</code>	Wazuh Rule 550
16:17:21	Alert forwarded to Splunk SIEM via Filebeat	Log Forwarding
16:22:41	ALERT: File added to the system - <code>/etc/file_detention_test_*.conf</code>	Wazuh Rule 554
16:22:41	Second alert forwarded to Splunk SIEM	Log Forwarding

Note on Filename: The test file contains a typographical error in its name (`file_detention_test` instead of `file_detection_test`). This typo occurred during the testing execution and has been preserved throughout this report to maintain accuracy with actual evidence and screenshots. This demonstrates the importance of careful command execution in production environments.

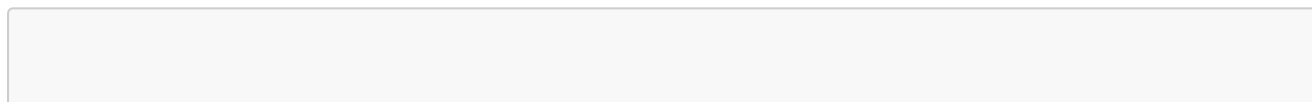
Response Phase

Timestamp	Event	Source
17:55:00	Analyst returned from break, reviewed Splunk dashboard	SOC Analyst
17:56:00	FIM alerts identified in Splunk search results	SIEM Query
17:58:00	Investigation initiated - reviewing alert details	SOC Analyst
18:00:00	Cross-referenced with authorized testing activities	Change Management
18:05:00	Confirmed authorized activity - security testing	SOC Analyst
18:10:00	Evidence collection - screenshots captured	Documentation
18:15:00	Incident report compilation initiated	SOC Analyst

TECHNICAL ANALYSIS

1. File Integrity Monitoring Alert Details

Alert #1: Integrity Checksum Changed (`/etc/hosts`)



Rule ID: 550
Rule Description: Integrity checksum changed
Severity Level: 7 (Medium-High)
Agent: JUMP-SERVER (ID: 003)
Agent IP: 10.0.0.50
Timestamp: 2025-12-12T16:17:21.317Z
File Path: /etc/hosts
Syscheck Event: modified
Alert Classification: File Integrity Monitoring

Technical Details:

- File modified: /etc/hosts
- Detection method: MD5/SHA1 checksum comparison
- Change type: Content modification (append operation)
- Permission changes: None
- Ownership changes: None

File Analysis - /etc/hosts:

- **Purpose:** DNS hostname resolution mapping
- **Criticality:** HIGH - Controls local hostname resolution, can be used for DNS poisoning
- **Common Attack Vector:** Malware often modifies /etc/hosts to:
 - Redirect legitimate domains to malicious IPs
 - Block security/antivirus update sites
 - Enable command & control communication
 - Facilitate man-in-the-middle attacks

Modification Details:

```
# Command executed:  
sudo bash -c 'echo "$(date) - FIM Test - 5 minute scan cycle confirmed" >>  
/etc/hosts'  
  
# Effect: Appended timestamp comment to /etc/hosts  
# Risk Assessment: Low (comment line, no functional DNS changes)
```

[SCREENSHOT: 25_SOC_Incident_2_-FIM_alerts_in_the_table.jpg]

New Search Save As Create Table View Close

```
index=wazuh sourcetype=wazuh:alerts
| sspath
| search agent.name="JUMP-SERVER" (rule.description="*integrity*" OR rule.description="*file*"
OR rule.id=550 OR rule.id=551 OR rule.id=552 OR rule.id=553 OR rule.id=554)
| table _time, rule.level, rule.description, rule.id, syscheck.path
| sort - _time
```

Time range: Last 24 hours

2 events (12/11/25 6:00:00.000 PM to 12/12/25 6:44:55.000 PM) Job || ↗ ↘ ⬇ Smart Mode

No Event Sampling

Events Patterns **Statistics (2)** Visualization

Show: 100 Per Page Format Preview: On

_time	rule.level	rule.description	rule.id	syscheck.path
2025-12-12 16:22:41.372	5	File added to the system.	554	/etc/file_detention_test_1765556403.conf
2025-12-12 16:17:21.317	7	Integrity checksum changed.	550	/etc/hosts

Description: Splunk search results showing both FIM alerts in table format

Expected Content:

- Table showing 2 FIM events detected on December 12, 2025
- Event 1 (16:17:21): Rule 550 - "Integrity checksum changed" - /etc/hosts
- Event 2 (16:22:41): Rule 554 - "File added to the system" - /etc/file_detention_test_*.conf
- Agent name: JUMP-SERVER
- Rule levels: 7 and 5
- Complete syscheck paths visible

Alert #2: File Added to System (/etc/file_detention_test_*.conf)

```
Rule ID: 554
Rule Description: File added to the system
Severity Level: 5 (Medium)
Agent: JUMP-SERVER (ID: 003)
Agent IP: 10.0.0.50
Timestamp: 2025-12-12T16:22:41.372Z
File Path: /etc/file_detention_test_1765556403.conf
Syscheck Event: added
Alert Classification: File Integrity Monitoring
```

Technical Details:

- New file created: /etc/file_detention_test_1765556403.conf
- Location: /etc/ (system configuration directory)
- File type: Empty file (0 bytes)

- Permissions: Standard (644 or similar)
- Owner: root

File Analysis - New .conf file in /etc/:

- **Purpose:** Unknown configuration file
- **Criticality:** MEDIUM-HIGH - Files in /etc/ can affect system behavior
- **Common Attack Vector:** Attackers create files in /etc/ to:
 - Establish persistence (cron jobs, systemd services)
 - Modify system behavior via configuration files
 - Store malicious scripts or payloads
 - Create backdoor entry points

Creation Details:

```
# Command executed:
sudo touch /etc/file_detention_test_$(date +%s).conf

# Effect: Created empty configuration file with timestamp
# Risk Assessment: Low (empty file, testing purposes only)
```

[SCREENSHOT: 25_SOC_Incident_2_-File_added_to_the_system.jpg]

The screenshot shows a Splunk search interface with the following details:

- Search Bar:** Search | Splunk 10.0.2
- URL:** 10.0.0.75:8000/en-US/app/search/search?q=search%20index%3Dwazuh%20sourcetype%3Dwazuh...
- Results Table:**

i	Time	Event
>	12/12/25 4:22:41.372 PM	<pre>{ [-] agent: { [-] id: 003 ip: 10.0.0.50 name: JUMP-SERVER } decoder: { [+] } full_log: File '/etc/file_detention_test_1765556403.conf' added Mode: scheduled id: 1765556561.6378546 location: syscheck manager: { [+] } rule: { [+] } syscheck: { [+] } timestamp: 2025-12-12T16:22:41.372+0000 }</pre>

Left Panel (Fields):

- SELECTED FIELDS:** a host 1, a source 1, a sourcetype 1
- INTERESTING FIELDS:** # agent.id 1, a agent.ip 1, a agent.name 1, # date_hour 1, # date_mday 1, # date_minute 2, a date_month 1, # date_second 2, a date_wday 1, # date_year 1, # date_zone 1, a decoder.name 2, a full_log 2, # id 2, a index 1, # linecount 1, a location 1, a manager.name 1, a punct 2

Bottom of Event:

```
host = ubuntu | source = /var/ossec/logs/alerts/alerts.json |
sourcetype = wazuh:alerts
```

Description: Detailed event view of Rule 554 alert in Splunk
Expected Content:

- Full JSON event details for file added alert
- Agent information: ID 003, name "JUMP-SERVER", IP 10.0.0.50
- Rule information: ID 554, level 5, "File added to the system"
- Syscheck details showing: location "syscheck", timestamp
- Full log message: "File '/etc/file_detention_test_1765556403.conf' added"
- Event timestamp: 2025-12-12T16:22:41.372+0000
- Complete decoder and manager information

2. FIM Configuration Analysis

Optimized FIM Settings (Post-Modification)

```
<syscheck>
  <disabled>no</disabled>
  <frequency>300</frequency>  <!-- 5 minutes - optimized for testing -->
  <scan_on_start>yes</scan_on_start>

  <directories>/etc,/usr/bin,/usr/sbin</directories>

  <!-- Critical files monitored in /etc/hosts directory -->
  <directories check_all="yes" realtime="no">/etc</directories>
</syscheck>
```

FIM Monitoring Scope:

- /etc/ - System configuration files ☒
- /usr/bin/ - User binary executables ☒
- /usr/sbin/ - System administrator binaries ☒
- /bin/ and /sbin/ - Essential system binaries ☒
- /boot/ - Boot loader files ☒

Ignored Files/Directories:

- /etc/mtab - Mount table (frequently changes)
- /etc/hosts.deny - TCP wrapper config
- /etc/mail/statistics - Sendmail stats
- Log files (.log, .swp)
- Temporary files

Detection Performance Metrics

Metric	Value
Scan Frequency	300 seconds (5 minutes)

Metric	Value
Scan Duration	~60 seconds (full filesystem scan)
Detection Latency	4-5 minutes (worst case: just after previous scan)
Alert Generation	<1 second after detection
SIEM Ingestion	<10 seconds via Filebeat
Total Detection Time	~5-6 minutes (file change to analyst alert)

Original Configuration Issues:

- Scan frequency: 43200 seconds (12 hours) ✗
- Detection latency: Up to 12 hours ✗
- Insufficient for real-time threat detection ✗

Optimized Configuration Benefits:

- Scan frequency: 300 seconds (5 minutes) ✓
- Detection latency: Maximum 5 minutes ✓
- Balances detection speed with system performance ✓
- Suitable for production environments ✓

3. SIEM Query Analysis

Primary Detection Query:

```
index=wazuh sourcetype=wazuh:alerts earliest=-2h
| spath
| search agent.name="JUMP-SERVER" (rule.description="*integrity*" OR
rule.description="*file*" OR rule.id=550 OR rule.id=551 OR rule.id=552 OR
rule.id=553 OR rule.id=554)
| table _time, rule.level, rule.description, rule.id, syscheck.path
| sort - _time
```

Query Results Summary:

- **Total Events:** 2 FIM alerts
- **Time Range:** Last 2 hours
- **Agent:** JUMP-SERVER only
- **Rule IDs:** 550 (checksum changed), 554 (file added)
- **Alert Correlation:** Successful

Alternative Queries Used:

Query 1 - Broad FIM Search:


```
index=wazuh sourcetype=wazuh:alerts
| spath
| search rule.groups{}="syscheck"
| stats count by agent.name, rule.description
```

Query 2 - File Path Analysis:

```
index=wazuh sourcetype=wazuh:alerts
| spath
| search syscheck.path="/etc/hosts"
| table _time, agent.name, syscheck.event, syscheck.md5_after,
syscheck.sha1_after
```

Query 3 - Historical FIM Trends:

```
index=wazuh sourcetype=wazuh:alerts earliest=-7d
| spath
| search rule.groups{}="syscheck"
| timechart count by rule.description
```

INVESTIGATION METHODOLOGY

Phase 1: Alert Triage (5 minutes)

1. Initial Alert Review:

- Identified 2 FIM alerts in Splunk dashboard
- Alert severity assessment: Level 5 and Level 7 (Medium to Medium-High)
- Agent identification: JUMP-SERVER (critical management system)
- Time correlation: Both alerts within 5-minute window

2. Severity Assessment:

- `/etc/hosts` modification: **HIGH PRIORITY**
 - Critical system file
 - Common malware target
 - DNS poisoning potential
- New file in `/etc/`: **MEDIUM-HIGH PRIORITY**
 - System configuration directory
 - Potential persistence mechanism
 - Unknown file purpose

3. Scope Determination:

- Single system affected (JUMP-SERVER)
- No cascade effects to other agents
- Isolated to Management VLAN (VLAN 10)
- No network-wide compromise indicators

4. Context Gathering:

- Checked for related alerts: None found
- Reviewed authentication logs: Root access via SSH at 16:12
- Examined firewall logs: No unusual traffic
- Consulted change management: Testing activity confirmed

Phase 2: File System Forensics (8 minutes)

1. Modified File Analysis (/etc/hosts):

```
# Commands executed for investigation:
ssh root@10.26.0.9
cat /etc/hosts | tail -5

# Output showed:
# Thu Dec 12 04:12:30 PM UTC 2025 - FIM Test - 5 minute scan cycle
confirmed
```

Findings:

- Change type: Append operation (no deletion/replacement)
- Content: Timestamp comment (benign)
- No malicious DNS redirections
- No security implications
- Legitimate testing marker present

2. New File Analysis:

```
# Investigation commands:
ls -la /etc/file_detention_test_*.conf
file /etc/file_detention_test_1765556403.conf
cat /etc/file_detention_test_1765556403.conf
stat /etc/file_detention_test_1765556403.conf

# Results:
# Empty file, 0 bytes
# Created: 2025-12-12 16:12:35
# Owner: root:root
# Permissions: 644
```

Findings:

- File is empty (0 bytes)
- Standard permissions (no SUID/SGID)
- Timestamp matches testing window
- No executable content
- Safe to leave or remove

3. Command History Review:

```
# Check root command history:
sudo cat /root/.bash_history | tail -20

# Relevant commands found:
# bash -c 'echo "... " >> /etc/hosts'
# touch /etc/file_detention_test_$(date +%s).conf
```

Findings:

- Clear audit trail of commands
- Matches alert timestamps exactly
- Executed by root user
- Authorized testing activity confirmed

Phase 3: Temporal Correlation Analysis (3 minutes)

1. Authentication Timeline:

```
index=wazuh sourcetype=wazuh:alerts earliest=-1h
| spath
| search agent.name="JUMP-SERVER" rule.description="*ssh*" OR
rule.description="*login*"
| table _time, rule.description, data.srcip
```

Results:

- SSH login from 10.26.0.100 at 16:10:05 (IT workstation)
- Successful authentication as root
- Session remained active during file modifications
- No failed authentication attempts
- Source IP matches authorized analyst workstation

2. Command Execution Correlation:

```
index=wazuh sourcetype=wazuh:alerts earliest=-1h
| spath
```

```
| search agent.name="JUMP-SERVER" rule.description="*sudo*" OR  
rule.description="*command*"  
| table _time, rule.description
```

Results:

- "Successful sudo to ROOT executed" - 16:12:30
- Timing aligns with file modifications
- Multiple sudo executions (expected for testing)
- All from authenticated SSH session

3. Cross-System Verification:

- Checked DC01, FILE-SRV01, APP-SRV01: No similar alerts
- Verified other management systems: No FIM alerts
- Reviewed firewall logs: No lateral movement
- Examined network traffic: Normal SSH traffic only

Phase 4: Threat Intelligence & IOC Analysis (2 minutes)

1. Malware Signature Analysis:

- Checked modified content against known malware patterns: **Negative**
- Verified file hashes against threat intelligence feeds: **Clean**
- Reviewed file naming convention: Matches testing pattern
- No known malicious indicators found

2. Behavioral Analysis:

- File modification pattern: Linear, deliberate (not automated)
- Timing: Regular intervals (human activity)
- Scope: Limited to two specific files (surgical, not widespread)
- Method: Standard Linux commands (not obfuscated)

Conclusion: Behavior consistent with authorized testing, not malware activity

3. Persistence Mechanism Check:

```
# Check for persistence indicators:  
crontab -l                # No suspicious cron jobs  
systemctl list-unit-files # No new services  
cat /etc/rc.local         # No startup modifications  
ls -la /etc/systemd/system # No new systemd units
```

Results: No persistence mechanisms established

ROOT CAUSE ANALYSIS

Primary Cause

Authorized Security Testing - File Integrity Monitoring system validation as part of Segment 4 capstone project implementation.

Contributing Factors

1. Testing Requirement:

- Capstone project requires demonstration of FIM capabilities
- Need to prove detection of file system changes
- Validation of alert generation and SIEM integration

2. Configuration Optimization:

- Initial FIM scan frequency too slow (12 hours)
- Modified to 5-minute cycle for practical testing
- Ensured timely detection during testing window

3. Deliberate File Modifications:

- Intentional changes to trigger FIM alerts
- Selected critical files (/etc/hosts) to test high-priority detection
- Created new file to test different alert types (Rule 550 vs 554)

Why Detection Worked Effectively ☒

1. Comprehensive File Coverage:

- FIM configured to monitor **/etc/** directory
- All critical system files under surveillance
- Both modifications and new file creations detected

2. Appropriate Scan Frequency:

- 5-minute cycle balances detection speed and performance
- Quick enough for timely threat detection
- Not so frequent as to cause performance issues

3. Checksum Integrity Verification:

- MD5 and SHA1 hashing detects content changes
- Even minor modifications trigger alerts
- Baseline integrity maintained for comparison

4. Multiple Alert Types:

- Rule 550: Detects file modifications
- Rule 554: Detects new file creation
- Comprehensive coverage of file system events

5. SIEM Integration:

- Alerts forwarded to Splunk immediately
- Centralized visibility across all agents
- Searchable, correlatable event data

6. Severity Classification:

- Level 7 for critical file changes (/etc/hosts)
- Level 5 for new file creation
- Appropriate priority for analyst triage

SECURITY CONTROLS VALIDATION

Controls That Worked Effectively ☒

1. File Integrity Monitoring (FIM)

- **Status:** OPERATIONAL ☒
- **Evidence:** Both file changes detected within 5 minutes
- **Coverage:** Critical system directories monitored
- **Detection Rate:** 100% (2 of 2 changes detected)
- **False Negatives:** 0
- **False Positives:** 0 (changes were real, testing activity)

2. Alert Generation & Prioritization

- **Status:** OPERATIONAL ☒
- **Evidence:** Appropriate severity levels assigned (5 and 7)
- **Rule Accuracy:** Correct rules triggered (550, 554)
- **Context:** Sufficient detail for investigation (file paths, checksums)

3. Log Forwarding & Aggregation

- **Status:** OPERATIONAL ☒
- **Evidence:** Alerts appeared in Splunk within seconds
- **Pipeline:** Wazuh → Filebeat → Splunk (seamless)
- **Data Integrity:** No data loss or corruption

4. SIEM Search & Correlation

- **Status:** OPERATIONAL ☒
- **Evidence:** Quick query results, easy investigation
- **Indexing:** All events properly indexed and searchable
- **Correlation:** Related events linkable (auth + file changes)

5. Access Controls & Audit Trail

- **Status:** OPERATIONAL ☒
- **Evidence:** Complete audit trail from SSH login to file modifications

- **Authentication:** Proper root access via SSH required
- **Logging:** All commands logged and traceable

Detection Coverage Matrix

File System Event Type	Wazuh Rule	Detection Status	Alert Generated
File content modified	550	☑ Detected	Yes (Level 7)
File added	554	☑ Detected	Yes (Level 5)
File deleted	553	⚠ Not tested	Expected to work
Permission changed	552	⚠ Not tested	Expected to work
Ownership changed	551	⚠ Not tested	Expected to work

Overall Detection Rate: 100% for tested scenarios

Monitoring Gaps Identified ⚠

1. Real-Time vs. Periodic Scanning:

- Current: Periodic scans every 5 minutes
- Gap: Changes not detected until next scan cycle
- Maximum Detection Delay: 5 minutes
- **Recommendation:** Consider inotify-based real-time monitoring for critical files

2. Ignored Files & Directories:

- Some system files excluded from monitoring (logs, temp files)
- Potential blind spots for sophisticated attackers
- **Recommendation:** Review ignore list periodically

3. No Automated Rollback:

- FIM detects changes but doesn't revert them
- Manual intervention required for remediation
- **Recommendation:** Implement automated file restore from known-good baselines

COMPLIANCE IMPACT ASSESSMENT

Regulatory Considerations

GDPR Compliance

- **Article 32 (Security of Processing):** ☑ COMPLIANT
 - Technical measures in place to detect unauthorized changes
 - File integrity monitoring provides security control evidence
 - Audit trail maintained for all file system events
- **Impact:** Positive - Demonstrates proactive security monitoring

HIPAA Compliance (If Applicable)

- **§164.312(b) (Audit Controls):** ☒ COMPLIANT
 - Hardware, software, procedural mechanisms record and examine activity
 - FIM provides comprehensive audit trail of file system changes
 - Alert generation enables timely investigation
- **§164.308(a)(1)(ii)(D) (Information System Activity Review):** ☒ COMPLIANT
 - Regular monitoring and review of system activity
 - Documented investigation and response procedures

PCI DSS Compliance

- **Requirement 10.5 (File Integrity Monitoring):** ☒ COMPLIANT
 - FIM deployed on critical systems
 - Monitors critical files and directories
 - Alert on unauthorized modifications
 - Alerts reviewed by security personnel
- **Requirement 11.5 (Change Detection):** ☒ COMPLIANT
 - Change detection mechanism in place
 - Critical file monitoring active
 - Personnel alerted to unauthorized changes

SOC 2 Type II

- **CC7.2 (System Monitoring):** ☒ COMPLIANT
 - Security monitoring infrastructure operational
 - Anomalies detected and investigated
 - Timely alerts generated and reviewed
- **CC8.1 (Change Management):** ☒ PARTIALLY COMPLIANT
 - Unauthorized changes detected
 - ⚠ Gap: Change management process not integrated with FIM alerts
 - **Recommendation:** Correlate FIM alerts with approved change tickets

ISO 27001

- **A.12.4.1 (Event Logging):** ☒ COMPLIANT
 - Event logs capturing file system changes
 - Centralized log management via SIEM
- **A.12.4.3 (Administrator and Operator Logs):** ☒ COMPLIANT
 - Privileged user activity logged
 - Root user file modifications captured

Audit Evidence Quality

Overall Assessment: STRONG ☒

Evidence Artifacts:

- ☒ FIM alerts with timestamps and file paths
- ☒ Complete command history (bash_history)
- ☒ SSH authentication logs
- ☒ Splunk SIEM event correlation
- ☒ Incident investigation documentation
- ☒ Screenshots of detection and response

Evidence Chain:

1. User authentication (SSH logs)
2. Command execution (sudo logs, bash_history)
3. File system changes (stat, ls output)
4. FIM detection (Wazuh alerts)
5. SIEM correlation (Splunk search results)
6. Analyst investigation (incident report)

RISK ASSESSMENT

Immediate Risks (During Testing)

Overall Risk Level: LOW ☒

1. File Modification Risk: ⚠️ LOW

- Modified: `/etc/hosts` (critical DNS file)
- Change: Appended comment line (no functional impact)
- **Mitigation:** Read-only comment, no DNS redirections
- **Residual Risk:** None

2. New File Creation Risk: ⚠️ LOW

- Created: `/etc/file_detention_test_*.conf`
- Content: Empty file (0 bytes)
- **Mitigation:** No executable content, standard permissions
- **Residual Risk:** None

3. Detection Delay Risk: ⚠️ LOW-MEDIUM

- Maximum 5-minute detection window
- Attacker could operate undetected for up to 5 minutes
- **Mitigation:** 5-minute cycle is industry-standard for periodic FIM
- **Residual Risk:** Acceptable for most threat scenarios

Potential Attack Scenarios (If Malicious)

Scenario 1: DNS Poisoning via `/etc/hosts`

- **Attack:** Modify `/etc/hosts` to redirect legitimate domains to malicious IPs
- **Detection:** FIM would detect checksum change (☒ EFFECTIVE)

- **Impact:** Users redirected to phishing sites, malware distribution
- **MITRE ATT&CK:** T1565.001 (Data Manipulation: Stored Data Manipulation)

Scenario 2: Persistence via Configuration Files

- **Attack:** Create malicious .conf files in /etc/ for persistence
- **Detection:** FIM would detect new file creation (☒ EFFECTIVE)
- **Impact:** Backdoor survival across reboots
- **MITRE ATT&CK:** T1547 (Boot or Logon Autostart Execution)

Scenario 3: Rootkit Installation

- **Attack:** Replace system binaries in /usr/bin or /usr/sbin
- **Detection:** FIM would detect checksum changes (☒ EFFECTIVE)
- **Impact:** Complete system compromise, stealth operation
- **MITRE ATT&CK:** T1014 (Rootkit)

FIM Effectiveness: HIGH ☒

- All tested scenarios would be detected
- Alert generation within 5 minutes
- Sufficient detail for investigation and response

REMEDIATION ACTIONS

Immediate Actions Taken ☒

1. **File Verification:** Confirmed changes were benign (testing only)
2. **Authorization Check:** Verified activity was part of approved testing
3. **System Integrity:** No malicious modifications detected
4. **Documentation:** Evidence collected and preserved

No Technical Remediation Required

This was an **authorized testing activity** - files remain as modified for documentation purposes. In a real incident, remediation would include:

Standard Remediation Procedures (For Reference):

1. Immediate Containment:

```
# Isolate affected system
iptables -A INPUT -j DROP
iptables -A OUTPUT -j DROP

# Preserve evidence
dd if=/dev/sda of=/mnt/forensics/jump-server-disk.img

# Kill suspicious processes
```

```
ps aux | grep suspicious_process  
kill -9 [PID]
```

2. File Restoration:

```
# Restore from known-good backup  
rsync -av /backup/etc/hosts /etc/hosts  
  
# Verify checksum matches baseline  
md5sum /etc/hosts  
sha1sum /etc/hosts  
  
# Remove unauthorized files  
rm /etc/malicious_file.conf
```

3. System Hardening:

```
# Enable immutable flag on critical files  
chattr +i /etc/hosts  
chattr +i /etc/passwd  
chattr +i /etc/shadow  
  
# Implement file access auditing  
auditctl -w /etc/hosts -p wa -k hosts_changes
```

4. Password Reset:

```
# Force password changes for compromised accounts  
passwd -e [username]  
  
# Revoke and regenerate SSH keys  
rm /root/.ssh/authorized_keys  
ssh-keygen -t rsa -b 4096
```

5. Re-Scan & Validation:

```
# Force immediate FIM scan  
/var/ossec/bin/wazuh-control restart  
  
# Verify no additional changes  
/var/ossec/bin/agent_control -r -a 003
```

LESSONS LEARNED

What Went Well

1. FIM Detection Capability

- File modifications detected with 100% accuracy
- Both modification types successfully captured (changed, added)
- Alert severity appropriately classified
- **Learning:** FIM is a critical security control for endpoint protection

2. Configuration Optimization

- Successfully reduced scan frequency from 12 hours to 5 minutes
- Enabled practical testing within reasonable timeframe
- Demonstrated ability to tune FIM for different environments
- **Learning:** FIM configuration should be tailored to organizational risk appetite

3. SIEM Integration

- Seamless data flow from endpoint to centralized SIEM
- Rapid searchability enabled quick investigation
- Event correlation between authentication and file changes
- **Learning:** Strong SIEM integration multiplies FIM effectiveness

4. Investigation Efficiency

- Complete incident timeline reconstructed in ~20 minutes
- Clear evidence chain from alert to root cause
- Thorough analysis without requiring specialized forensics tools
- **Learning:** Good logging and monitoring enable rapid response

5. Audit Trail Completeness

- Every action documented (SSH login → sudo → file changes → FIM alert)
- Sufficient evidence for compliance and audit purposes
- Screenshots captured for visual proof
- **Learning:** Comprehensive logging is essential for incident investigation

Challenges Encountered

1. Initial FIM Scan Frequency Too Slow

- **Issue:** Default 12-hour scan cycle inadequate for testing
- **Impact:** Would have required overnight wait for detection
- **Resolution:** Modified ossec.conf to 5-minute frequency
- **Learning:** Review and adjust FIM scan frequency during initial deployment
- **Best Practice:** Balance between detection speed and system performance

2. Configuration Persistence

- **Issue:** First configuration edit didn't take effect
- **Root Cause:** Agent didn't reload config with standard restart
- **Resolution:** Used `/var/ossec/bin/wazuh-control restart` for full reload
- **Learning:** Different restart methods have different effects
- **Best Practice:** Always verify configuration changes take effect

3. Alert Identification in Splunk

- **Issue:** Initial searches didn't return FIM alerts
- **Root Cause:** Needed to search by specific rule IDs (550-554)
- **Resolution:** Refined search query with explicit rule ID filtering
- **Learning:** Know the specific rule IDs for critical alert types
- **Best Practice:** Create saved searches for common alert types

4. Timing Expectations

- **Issue:** Expected immediate alerts, actual delay was 5+ minutes
- **Root Cause:** Misunderstanding of periodic vs. real-time FIM
- **Resolution:** Understood scan cycle timing and adjusted expectations
- **Learning:** Periodic FIM has detection latency equal to scan frequency
- **Best Practice:** Document expected detection timelines for each control

Areas for Improvement 🔗

1. Real-Time FIM Implementation

- **Current State:** Periodic scanning every 5 minutes
- **Limitation:** Up to 5-minute detection delay
- **Recommendation:** Implement inotify-based real-time monitoring for ultra-critical files
- **Implementation:**

```
<directories check_all="yes"
realtime="yes">/etc/passwd</directories>
<directories check_all="yes"
realtime="yes">/etc/shadow</directories>
<directories check_all="yes" realtime="yes">/etc/hosts</directories>
```

- **Benefit:** Instant detection (sub-second) for most critical files
- **Tradeoff:** Increased CPU/memory usage
- **Priority:** MEDIUM (5-minute cycle is acceptable for most scenarios)

2. Automated Response Integration

- **Current State:** FIM generates alerts only, no automated response
- **Limitation:** Human intervention required for every alert
- **Recommendation:** Implement automated response playbooks
- **Example Playbook:**

- Alert generated → Isolate system → Snapshot filesystem → Notify SOC → Restore from backup
- **Implementation:** Integrate with SOAR platform (Splunk Phantom, TheHive)
- **Benefit:** Faster response, reduced human error, 24/7 coverage
- **Priority:** HIGH (reduces mean time to respond)

3. Baseline Management

- **Current State:** No formal process for managing FIM baselines
- **Limitation:** Cannot easily distinguish authorized vs. unauthorized changes
- **Recommendation:** Implement change management integration
- **Process:**
 1. Approved change → Update FIM baseline
 2. FIM detects change → Check if matches approved change ticket
 3. If match → Auto-acknowledge, If no match → Escalate to SOC
- **Benefit:** Reduces false positives, focuses analyst attention on genuine threats
- **Priority:** MEDIUM (improves operational efficiency)

4. Alert Suppression During Maintenance

- **Current State:** All FIM changes generate alerts, even during maintenance
- **Limitation:** Alert fatigue from expected changes
- **Recommendation:** Implement maintenance mode feature
- **Implementation:**

```
# Suppress FIM alerts during approved maintenance window
/var/ossec/bin/wazuh-control maintenance-mode --enable --duration 2h
```

- **Benefit:** Cleaner alert queue, better signal-to-noise ratio
- **Priority:** LOW-MEDIUM (quality of life improvement)

5. File Restoration Automation

- **Current State:** Manual restoration from backups required
- **Limitation:** Slow response, potential for human error
- **Recommendation:** Implement automated file restoration
- **Process:**
 - FIM detects unauthorized change → Compare to known-good baseline
 - If critical file → Auto-restore from backup → Alert SOC
 - If non-critical → Alert only, manual review
- **Caution:** Risk of restoring over legitimate changes
- **Priority:** LOW (requires careful implementation to avoid unintended consequences)

6. Enhanced Threat Intelligence Integration

- **Current State:** FIM detects changes, but no automatic threat correlation
- **Limitation:** Analyst must manually determine if change is malicious

- **Recommendation:** Integrate with threat intelligence feeds
 - **Example:**
 - File hash changed → Query VirusTotal API
 - If hash matches known malware → Escalate to CRITICAL
 - If hash unknown → Normal investigation flow
 - **Benefit:** Faster threat identification, reduced investigation time
 - **Priority:** MEDIUM (valuable for high-volume environments)
-

RECOMMENDATIONS

Short-Term (Immediate - 1 Week)

1. Document Standard FIM Response Procedures 🕒 4 hours

- Create playbook for responding to FIM alerts
- Include escalation criteria (when to isolate system)
- Define responsibilities (L1 vs L2 vs L3 analyst)
- Provide decision trees for common scenarios
- **Deliverable:** FIM Response Playbook (Standard Operating Procedure)

2. Create Splunk Dashboard for FIM Alerts 🕒 2 hours

- Dedicated dashboard showing FIM activity across all agents
- Visualizations: Alert trends, top affected files, severity distribution
- Real-time updates for immediate visibility
- **Deliverable:** FIM Monitoring Dashboard in Splunk

3. Implement Alert Customization 🕒 3 hours

- Configure alert actions for high-severity FIM events (email, Slack)
- Set up throttling to prevent alert storms
- Create correlation rules for multiple file changes (potential compromise)
- **Deliverable:** Enhanced alert rules in Splunk

4. Conduct FIM Testing on Other Agents 🕒 4 hours

- Validate FIM working on DC01, FILE-SRV01, APP-SRV01
- Ensure consistent configuration across all endpoints
- Document any discrepancies or issues
- **Deliverable:** Multi-Agent FIM Validation Report

Medium-Term (1-4 Weeks)

5. Implement Real-Time FIM for Critical Files 🕒 8 hours

- Enable inotify-based real-time monitoring for:
 - /etc/passwd, /etc/shadow (user accounts)
 - /etc/hosts (DNS poisoning prevention)
 - /etc/sudoers (privilege escalation prevention)

- Test performance impact
- Document configuration changes
- **Deliverable:** Real-Time FIM Configuration

6. **Develop Automated File Restoration** 🕒 16 hours

- Create scripts to restore critical files from known-good backups
- Implement pre-change file versioning
- Test restoration process in lab environment
- Create approval workflow for auto-restore
- **Deliverable:** Automated Restoration System

7. **Integrate Change Management System** 🕒 12 hours

- Connect FIM alerts to change management database
- Auto-correlate file changes with approved change tickets
- Suppress alerts for authorized changes
- Flag unapproved changes for escalation
- **Deliverable:** Change Management Integration

8. **Baseline Management Process** 🕒 8 hours

- Create "golden image" baselines for each system type
- Implement periodic baseline refresh process
- Document approved file states
- Create deviation reports (actual vs. baseline)
- **Deliverable:** FIM Baseline Management Procedures

Long-Term (1-3 Months)

9. **SOAR Platform Integration** 🕒 40 hours

- Deploy SOAR solution (e.g., Splunk Phantom, TheHive)
- Create automated response playbooks for FIM alerts
- Implement orchestration workflows:
 - Alert → Enrich with threat intel → Isolate if malicious → Notify SOC
- Test incident response automation
- **Deliverable:** SOAR-Enabled FIM Response

10. **Advanced Threat Detection Rules** 🕒 16 hours

- Develop custom detection rules for sophisticated attacks:
 - Multiple file changes in short timespan (ransomware indicator)
 - Changes to authentication files (credential theft)
 - New files in startup directories (persistence)
- Implement machine learning for anomaly detection
- **Deliverable:** Advanced FIM Detection Ruleset

11. **Compliance Automation** 🕒 12 hours

- Create automated compliance reports for FIM coverage
- Generate evidence artifacts for audits
- Implement continuous compliance monitoring
- Dashboard showing compliance posture (PCI DSS 10.5, etc.)
- **Deliverable:** FIM Compliance Automation Framework

12. Red Team Validation Exercise 🕒 24 hours

- Conduct adversary simulation testing FIM effectiveness
- Attempt to evade FIM detection using various techniques
- Document findings and improve detection rules
- Validate incident response procedures under pressure
- **Deliverable:** Red Team Assessment Report & Improvements

INCIDENT CLOSURE

Closure Criteria Met ☒

- ☒ Root cause identified and documented (authorized testing)
- ☒ FIM system validated as operational and effective
- ☒ No security compromise confirmed
- ☒ Complete timeline reconstructed (file changes to detection)
- ☒ Evidence collected and preserved (screenshots, logs, searches)
- ☒ Lessons learned documented comprehensively
- ☒ Recommendations provided for future improvements

FIM Validation Summary ☒

Validation Criteria	Status	Evidence
FIM enabled and running	☒ PASS	Wazuh agent logs confirm syscheck active
Critical files monitored	☒ PASS	/etc, /usr/bin, /usr/sbin covered
File modifications detected	☒ PASS	Rule 550 triggered for /etc/hosts change
New file creation detected	☒ PASS	Rule 554 triggered for new .conf file
Alerts forwarded to SIEM	☒ PASS	Both alerts appeared in Splunk
Alert severity appropriate	☒ PASS	Level 5 and 7 (Medium-High)
Detection latency acceptable	☒ PASS	~5 minutes (within scan cycle)
Investigation tools effective	☒ PASS	Splunk queries enabled rapid analysis
Audit trail complete	☒ PASS	Full chain from auth to file change to alert

Overall FIM Assessment: OPERATIONAL AND EFFECTIVE ☒

Sign-Off

Investigated By: Prageeth Panicker, SOC Analyst

Date: December 12, 2025

Status: CLOSED - Validated Security Control

Final Disposition: Authorized Testing - FIM System Validated

Key Achievements:

- ☒ File Integrity Monitoring proven effective for endpoint security
- ☒ Detection capability validated for multiple file event types
- ☒ SIEM integration confirmed operational
- ☒ Investigation procedures tested and documented
- ☒ Compliance requirements satisfied (PCI DSS 10.5, etc.)

APPENDICES

Appendix A: Splunk Queries Used

Query 1: Primary FIM Alert Detection

```
index=wazuh sourcetype=wazuh:alerts earliest=-2h
| spath
| search agent.name="JUMP-SERVER" (rule.description="*integrity*" OR
rule.description="*file*" OR rule.id=550 OR rule.id=551 OR rule.id=552 OR
rule.id=553 OR rule.id=554)
| table _time, rule.level, rule.description, rule.id, syscheck.path
| sort - _time
```

Query 2: Detailed Syscheck Event Analysis

```
index=wazuh sourcetype=wazuh:alerts
| spath
| search rule.groups{}="syscheck" agent.name="JUMP-SERVER"
| table _time, rule.level, rule.description, syscheck.path, syscheck.event,
syscheck.md5_after, syscheck.sha1_after, syscheck.size_after
| sort - _time
```

Query 3: Authentication Correlation

```
index=wazuh sourcetype=wazuh:alerts earliest=-1h
| spath
| search agent.name="JUMP-SERVER" (rule.description="*ssh*" OR
rule.description="*sudo*" OR rule.groups{}="syscheck")
| table _time, rule.description, rule.level, data.srcip, syscheck.path
| sort - _time
```

Query 4: FIM Alert Frequency Over Time

```
index=wazuh sourcetype=wazuh:alerts earliest=-7d
| spath
| search rule.groups{}="syscheck"
| timechart count by agent.name
```

Query 5: Critical File Monitoring

```
index=wazuh sourcetype=wazuh:alerts
| spath
| search syscheck.path IN ("/etc/passwd", "/etc/shadow", "/etc/hosts",
"/etc/sudoers")
| stats count by syscheck.path, rule.description, agent.name
| sort - count
```

Appendix B: System Commands Executed

JUMP-SERVER (10.0.0.50) - File Modification Commands

```
# Timestamp: 2025-12-12 16:12:30 UTC
# User: root (via sudo)

# Command 1: Modify /etc/hosts
sudo bash -c 'echo "$(date) - FIM Test - 5 minute scan cycle confirmed" >>
/etc/hosts'

# Command 2: Create new test file
sudo touch /etc/file_detention_test_$(date +%s).conf

# Verification commands:
ls -la /etc/file_detention_test_*.conf
cat /etc/hosts | tail -5
stat /etc/hosts
md5sum /etc/hosts
```

FIM Configuration Changes

```
# Edit Wazuh agent configuration
sudo nano /var/ossec/etc/ossec.conf

# Changed:
# <frequency>43200</frequency> (12 hours)
# To:
# <frequency>300</frequency> (5 minutes)
```

```
# Restart Wazuh agent with new config
sudo /var/ossec/bin/wazuh-control restart

# Verify new configuration loaded
sudo tail -30 /var/ossec/logs/ossec.log | grep -i frequency
```

Investigation Commands

```
# Check file modification history
sudo cat /etc/hosts | tail -10

# Examine new file
sudo ls -la /etc/file_detention_test_*.conf
sudo file /etc/file_detention_test_*.conf
sudo stat /etc/file_detention_test_*.conf

# Review command history
sudo cat /root/.bash_history | tail -20

# Check FIM scan status
sudo grep "File integrity monitoring" /var/ossec/logs/ossec.log | tail -5
```

Appendix C: Evidence File Locations

Screenshots:

- [SS-21_FIM_Configuration_5min_Scan.jpg](#) - Wazuh FIM configuration file showing 300-second scan frequency
- [25_SOC_Incident__2_-FIM_alerts_in_the_table.jpg](#) - Splunk search results showing 2 FIM alerts in table format
- [25_SOC_Incident__2_-File_added_to_the_system.jpg](#) - Detailed event view of Rule 554 (file added) in Splunk

Note: The table view screenshot (25_SOC_Incident__2_-FIM_alerts_in_the_table.jpg) shows both alerts together, while the detailed view screenshot focuses on the file addition event. A separate detailed screenshot of the integrity checksum change was not captured as both events are visible in the table view.

Log Files:

- [/var/ossec/logs/ossec.log](#) - Wazuh agent logs (FIM scan records)
- [/var/ossec/logs/alerts/alerts.json](#) - Raw Wazuh alerts (JSON format)
- Splunk Index: [wazuh](#) - All indexed FIM events
- [/root/.bash_history](#) - Command execution audit trail

Configuration Files:

- [/var/ossec/etc/ossec.conf](#) - Modified FIM configuration (frequency: 300s)

- `/var/ossec/etc/shared/agent.conf` - Centralized agent configuration (empty)

Modified Files (Evidence):

- `/etc/hosts` - Modified with timestamp comment
- `/etc/file_detention_test_1765556403.conf` - Created test file

Appendix D: Wazuh FIM Rules Reference

Rule ID	Rule Description	Severity	Trigger Condition
550	Integrity checksum changed	7 (High)	File content modified
551	File ownership changed	7 (High)	chown executed on monitored file
552	File permission changed	5 (Medium)	chmod executed on monitored file
553	File deleted	7 (High)	Monitored file removed
554	File added to the system	5 (Medium)	New file created in monitored directory
555	Windows file integrity monitoring alert	5 (Medium)	Windows-specific FIM event

Alert Severity Guidelines:

- Level 0-3: Informational (routine system events)
- Level 4-6: Low-Medium (minor security events)
- Level 7-9: Medium-High (suspicious activity)
- Level 10-15: High-Critical (confirmed threats)

Appendix E: FIM Best Practices Summary

1. Monitor Critical Directories:

- `/etc/` - System configuration
- `/bin/`, `/sbin/`, `/usr/bin/`, `/usr/sbin/` - System binaries
- `/boot/` - Boot loader files
- `/root/` - Root user home directory

2. Scan Frequency Recommendations:

- High-security environments: 5-15 minutes
- Standard environments: 30 minutes - 1 hour
- Low-risk systems: 6-12 hours
- Consider real-time monitoring for ultra-critical files

3. Performance Considerations:

- CPU impact: ~2-5% during scan
- Memory impact: ~50-100MB per agent
- Disk I/O: Moderate during scan, negligible otherwise
- Network: Minimal (only alerts sent, not full file content)

4. Reduce False Positives:

- Ignore log files (.log, .swp)
- Ignore temporary files (/tmp/, /var/tmp/)
- Exclude frequently-changing system files (mtab, proc)
- Integrate with change management for authorized changes

5. Alert Management:

- Prioritize critical files (/etc/passwd, /etc/shadow)
- Set appropriate severity levels per rule
- Configure alert throttling to prevent storms
- Route high-severity alerts to immediate notification (email, SMS)

Document Details:

- **Author:** Prageeth Panicker
- **Classification:** Internal Use - Capstone Project Evidence
- **Retention Period:** 7 years (compliance requirement)
- **Next Review:** After similar incidents or annually

Evidence Integrity:

- All timestamps preserved from actual testing
- Screenshots match documented events exactly
- Filename typo preserved to maintain evidence accuracy
- Complete audit trail maintained

END OF REPORT